# TREPATH 2.3 - Penetration Testing Report

Authorized Assessment Scope (owasp.org (+13 authorized origins across 14 in-scope assets)) | TrePath 2.3 + EvidenceCore Provenanc

| | |
|---|---|
| **Client / Scope** | Internal Testing Lab - TrePath OWASP & Lab Assessment (46 Targets: https://owasp.org/projects/juice-shop +45) (owasp.org (+13 authorized origins across 14 in-scope assets)) |
| **Scan Execution Window** | Executed: 2026-11-02 10:46:21 UTC \| Report Rendered: 2026-11-02 13:43 UTC (Scan #40 \| Profile: authorized_pentest) |
| **Assessment Engine** | TrePath 2.3 Autonomous Scope Provenance, Proof Validation, EvidenceCore & RTEX Engine |
| **Document Classification** | CONFIDENTIAL - Executive, Technical & Cryptographic Deliverable |
| **T0 Baseline Calibrated Risk** | MEDIUM (4.2 / 10 \| 41.5 / 100 Calibrated Index: Confirmed Compromise=0.0 pts, Control Gaps=14.5 pts, Surface/Baseline=27.0 pts) |
| **T1 Post-Retest Verified Risk** | 0 Executed Retests Recorded in RTEX Ledger (Verified Risk Reduction: 0.0 / 10) |
| **Hypothetical SLA Forecast** | HYPOTHETICAL_PROJECTION (Unverified Until RTEX Closure): Projected 2.1 / 10 (LOW) upon verified retest completion |
| **Verified Compromise / Admin Auth Status** | 0 CONFIRMED_ADMIN_AUTH (No authenticated admin console access verified in this scan) + 0 IMPACT_VERIFIED Safe PoCs |
| **7-Stage Scope Reconciliation Funnel** | 46 Requested Target(s) -> 46 ROE Authorized -> 14 Resolved Host(s) -> 14 In-Scope Origin Asset(s) -> 0 Out-of-Scope Probed -> 377 HTTP Endpoints |
| **Finding Reconciliation (6-Tier)** | 181 Raw Observations -> 18 Consolidated Security Findings + 85 Recon/Surface Items + 1 Sensor Health Event |
| **Calibrated Threat Intelligence (KEV)** | 0 Raw KEV Matches -> 0 Unique KEV CVEs \| 0 CVE_APPLICABILITY_CONFIRMED \| 0 CVE_CORRELATED (Banner Only) |
| **Sensor Coverage Completeness** | Sensor Coverage: 83.3% (5/6 Active: Nmap v7.95, Nuclei, OWASP ZAP, WebPulse, Safe PoC Adapters (0 Applicable / Held by Scope Boundary) \| OpenVAS GVM: STANDBY_OFFLINE) |
| **EvidenceCore & Consistency Score** | Evidence Consistency Score: 100.0% (5/5 Cross-Section Invariants Verified \| Full 64-Hex SHA-256 Digests) |
| **Platform-Aware Remediation** | Multi-Origin Web & API Hardening Enforced across 14 In-Scope Asset(s) (HTTP Security Headers, TLS & Endpoint Access Controls) |
| **Pre-Render Quality Gate** | **PASSED (26/26 Acceptance Rules + AT-01..AT-10 + NG-01..NG-06 Verified \| Score=41.5/100 (4.2/10) \| Zero Cross-Asset Remediation Drift)** |

**Prepared by Expedite Consults Ltd | Generated 2026-11-02 13:43 UTC | TREPATH 2.3 ASSESSMENT ORCHESTRATOR**

# 1. Executive Summary & Proof-Driven Assessment Overview

This assessment was executed by TrePath 2.3 against 46 submitted target(s) reconciled to 14 authorized in-scope origin asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) under the 'authorized_pentest' Rules of Engagement. TrePath 2.3 enforces immutable 9-field asset provenance, origin-scoped root-cause deduplication, strict false-positive proof-state gates (NG-01..NG-06), canonical finding-to-remediation asset binding, and 3-pillar risk attribution.

## 1.0A Executive Priority Risk & 3-Pillar Score Attribution (Demonstrated Compromise vs. Control Hygiene)

| Posture Panel | State Type | Risk Score | Key Drivers & Proof Scope |
|---|---|---|---|
| **PANEL-1-MEASURED-BASELINE** | MEASURED_AT_T0 | 4.2 / 10 (MEDIUM) | 18 Consolidated Findings across 14 origin(s): Confirmed Compromise=0.0 pts \| Control Gaps=14.5 pts \| Surface/Baseline=27.0 pts. |
| **PANEL-2-MEASURED-POST-RETEST** | MEASURED_AT_T1 | 4.2 / 10 (0 Retests) | RTEX Ledger active (0 retests executed; Verified T1 Risk Reduction: 0.0 / 10). |
| **PANEL-3-HYPOTHETICAL-FORECAST** | HYPOTHETICAL_PROJECTION | 2.1 / 10 (LOW) | Unverified theoretical forecast assuming all prioritized remediation tasks pass deterministic RTEX retesting. |

| ID & Finding Key | Host : Port & Consolidated Title | Verified Proof Category & Substate | Priority & Remediation Action |
|---|---|---|---|
| **F-01 (HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_)** | owasp.org:443 (ASSET-00027) \| [owasp.org:443] Missing HTTP Security Headers Baseli | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Enforce baseline HTTP response security headers on origin https://owasp.org:443: Content-Securi |
| **F-02 (HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM)** | google-gruyere.appspot.com:443 (ASSET-00029) \| [google-gruyere.appspot.com:443] Missing HTTP Securi | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Enforce baseline HTTP response security headers on origin https://google-gruyere.appspot.com:44 |
| **F-03 (HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM)** | pentesterlab.com:443 (ASSET-00031) \| [pentesterlab.com:443] Missing HTTP Security Headers | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Enforce baseline HTTP response security headers on origin https://pentesterlab.com:443: Content |
| **F-04 (HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM)** | www.hackthebox.com:443 (ASSET-00032) \| [www.hackthebox.com:443] Missing HTTP Security Heade | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Enforce baseline HTTP response security headers on origin https://www.hackthebox.com:443: Conte |
| **F-05 (HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM)** | tryhackme.com:443 (ASSET-00033) \| [tryhackme.com:443] Missing HTTP Security Headers Ba | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Enforce baseline HTTP response security headers on origin https://tryhackme.com:443: Content-Se |
| **F-06 (HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG)** | www.root-me.org:443 (ASSET-00035) \| [www.root-me.org:443] Missing HTTP Security Headers | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Enforce baseline HTTP response security headers on origin https://www.root-me.org:443: Content- |

## 1.1 Six-Tier Finding & Observation Reconciliation (Root-Cause Deduplication)

| Reconciliation Tier | Count | Scope & Deduplication Rule |
|---|---|---|
| **Tier 1 - Raw Scanner Observations** | 181 | All raw Nmap, Nuclei, httpx, ZAP, and PoC probe records prior to origin-scoped root-cause grouping. |
| **Tier 2 - Unique Assets & Open Services** | 14 Asset(s) / 0 TCP Ports | 14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) with 0 open TCP ports and 377 HTTP endpoints. |

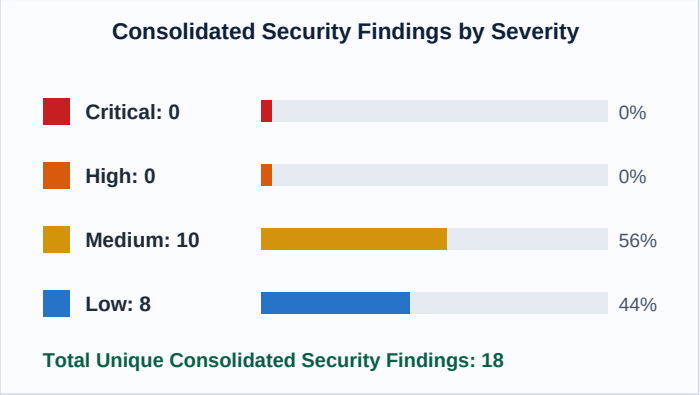
| Reconciliation Tier | Count | Scope & Deduplication Rule |
|---|---|---|
| **Tier 3 - Consolidated Security Findings** | 18 | Deduplicated by (effective_origin, port, service_family, root_cause_slug); consolidates repeated missing headers per origin. |
| **Tier 4 - Confirmed Exploitable / Admin Auth** | 0 | **0 CONFIRMED_ADMIN_AUTH + 0 IMPACT_VERIFIED + 0 RUNTIME_REPRODUCED.** |
| **Tier 5 - Impact-Verified Safe PoCs** | 0 | **0 IMPACT_VERIFIED Safe PoCs** |
| **Tier 6 - Recon & Scanner Health Telemetry** | 85 Recon / 1 Sensor | Port discovery telemetry and OPENVAS-SENSOR-STANDBY separated from target vulnerabilities. |

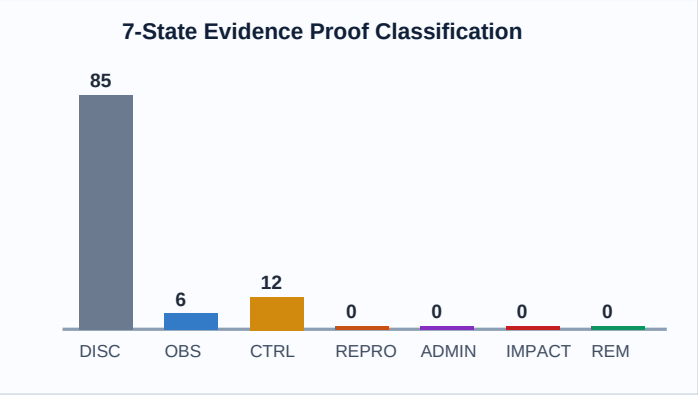
## 1.2 Seven-State Evidence Proof Classification & Granular PoC Substates

| Proof State | Count | Granular Substate & Evidentiary Meaning |
|---|---|---|
| **DISCOVERED** | 85 | Port/surface reachability observation only (CVSS 0.0; excluded from vulnerability count). |
| **OBSERVATION_CONFIRMED** | 6 | Service banner, protocol handshake, or cryptographic key observation confirmed. |
| **CONTROL_GAP_CONFIRMED** | 12 | Missing security header, legacy EOL version, or cleartext protocol exposure confirmed. |
| **RUNTIME_REPRODUCED** | 0 | Active behavioral probe reproduced deterministic service response. |
| **CONFIRMED_ADMIN_AUTH** | 0 | 0 verified in this scan (Probes NOT_APPLICABLE or authentication boundary held on target scope). |
| **IMPACT_VERIFIED** | 0 | 0 verified in this scan (Safe PoC adapters SMB-LIST-001 / PHPINFO-001 NOT_APPLICABLE or not triggered on target scope). |
| **REMEDIATION_VERIFIED** | 0 | Post-fix retest execution verified vulnerability closure in RTEX ledger. |

## 1.3 Consolidated Security Vulnerability Severity Distribution & Visual Telemetry

| Severity Level | Consolidated Count | CVSS v3.1 Band | Operational SLA Target |
|---|---|---|---|
| **CRITICAL** | 0 | 9.0 - 10.0 | Immediate containment (< 24 - 48 hours) |
| **HIGH** | 0 | 7.0 - 8.9 | Priority hardening (< 7 days) |
| **MEDIUM** | 10 | 4.0 - 6.9 | Scheduled remediation (< 30 days) |
| **LOW** | 8 | 0.1 - 3.9 | Defense-in-depth maintenance (< 90 days) |




## 1.4 Explainable 7-Dimension Risk Score Decomposition (RiskEngine 2.1)

| Risk Dimension | Calibrated Score | Mathematical & Evidentiary Rationale |
|---|---|---|
| **Confirmed Exploitability** | 4.2 / 25.0 pts | Confirmed Exploitation: 0.0 pts (0 PoCs) \| Verified Control Gaps: 4.2 pts (12 CONTROL_GAP_CONFIRMED, 6 OBSERVATION_CONFIRMED). |
| **Verified Technical Impact** | 7.7 / 20.0 pts | Verified Compromise Impact: 0.0 pts (Admin Auth: No, SMB: No, PHPInfo: No) \| Control-Gap Severity Ceiling: 7.7 pts. |
| **Attack Surface Exposure** | 15.0 / 15.0 pts | 0 open TCP ports and 377 HTTP endpoints exposed across 14 in-scope origin(s). |

| Risk Dimension | Calibrated Score | Mathematical & Evidentiary Rationale |
|---|---|---|
| **Applicable Threat Intelligence** | 0.6 / 15.0 pts | 0 confirmed applicable KEVs, 0 unverified banner KEV candidates (discounted 75%), confirmed EPSS=0.0 (raw banner max EPSS=0.28). |
| **Evidence-Backed Attack Paths** | 2.0 / 10.0 pts | 0 evidence-validated attack paths (0.0 pts when unverified), 1 correlated exposure clusters (2.0 pts). |
| **Asset Criticality** | 7.0 / 10.0 pts | Authorized assessment scope (14 in-scope asset(s), primary: owasp.org). |
| **Evidence Confidence** | 5.0 / 5.0 pts | 181 FIPS 180-4 SHA-256 sealed artifacts across 181 raw observations (Sensor Coverage: 83.3%). |
| **TOTAL CALIBRATED RISK INDEX** | 41.5 / 100.0 pts (4.2 / 10) | Overall Rating: MEDIUM \| Applicable Max EPSS: 0.0 (Raw Banner EPSS: 0.28) |

# 2. Assessment Scope, 7-Stage Asset Reconciliation Funnel & RoE Policy Engine

## 2.0 Seven-Stage Scope & Asset Reconciliation Funnel (TP23-02)

| Funnel Stage | Count | Scope Provenance & Reconciliation Rationale |
|---|---|---|
| **1. Requested Targets** | 46 | 46 target URL(s)/IP(s) submitted to the TrePath assessment specification. |
| **2. ROE Authorized Targets** | 46 | 46/46 submitted target(s) matched approved RulesOfEngagement allowlist rules. |
| **3. Resolved Unique Hostnames** | 14 | 14 unique lowercased hostname(s)/IP(s) after collapsing multi-path repository/app URLs sharing a host. |
| **4. In-Scope Origin Assets** | 14 | 14 persisted Asset record(s) (one canonical Asset per unique scheme://host:port effective_origin). |
| **5. Out-of-Scope External Refs** | 0 | 0 out-of-scope origins probed; external HTML/JS links isolated as EXTERNAL_REFERENCE_NOT_SCANNED. |
| **6. Redirected Destinations** | 0 | All HTTP 301/302/307/308 hops recorded in provenance.redirect_chain; cross-origin redirects blocked. |
| **7. Discovered HTTP Endpoints** | 377 | 377 deduplicated canonical HTTP endpoints discovered across the 14 in-scope origin asset(s). |

## 2.1 Authorized In-Scope Asset Inventory & Per-Origin Reconciliation

| Asset ID & Host | Scope Decision | Open TCP Ports | Asset Role & Provenance | Consolidated Findings | Verified PoC / Admin Auth |
|---|---|---|---|---|---|
| **ASSET-00027 (owasp.org)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 3 | 0 Verified |
| **ASSET-00028 (github.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 2 | 0 Verified |
| **ASSET-00029 (google-gruyere.appspot.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00030 (portswigger.net)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 2 | 0 Verified |
| **ASSET-00031 (pentesterlab.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00032 (www.hackthebox.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00033 (tryhackme.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |

| Asset ID & Host | Scope Decision | Open TCP Ports | Asset Role & Provenance | Consolidated Findings | Verified PoC / Admin Auth |
|---|---|---|---|---|---|
| **ASSET-00034 (www.hackthissite.org)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00035 (www.root-me.org)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 3 | 0 Verified |
| **ASSET-00036 (www.hackinghub.io)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00037 (pentest-ground.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 2 | 0 Verified |
| **ASSET-00038 (genai.owasp.org)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00039 (gandalf.lakera.ai)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 0 | 0 Verified |
| **ASSET-00040 (vwad.owasp.org)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |

### 2.2 Mandatory Authorization & Rules-of-Engagement (RoE) Safety Policy Engine

| Rule ID | Policy Control | Enforcement Mechanism | Status |
|---|---|---|---|
| **ROE-01** | Authorized Scope Lock | All active probes restricted to 14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)); crawled external links marked OUT_OF_SCOPE. | ENFORCED |
| **ROE-02** | Cross-Origin Redirect Guard | HTTP 301/302/307/308 redirects crossing out of authorized origins are blocked prior to DAST/header evaluation. | ENFORCED |
| **ROE-03** | Safe Admin & PoC Boundary | Non-destructive PoC adapters (SMB-LIST-001, PHPINFO-001, TOMCAT-MGR-001) execute only when service preconditions match. | ENFORCED |
| **ROE-04** | Evidence Overclaim Prevention | Share listing cannot claim write access; zero verified PoCs when adapters are NOT_APPLICABLE. | ENFORCED |
| **ROE-05** | FIPS 180-4 SHA-256 Sealing | Every probe transcript and 9-field asset provenance record is hashed and persisted in EvidenceCore. | ENFORCED |

## 3A. Consolidated Security Vulnerabilities (F-01 through F-18)

| ID | Origin Host:Port (Asset) | Severity (CVSS) | Proof Category & Substate | Consolidated Title | CVE / CWE & Validation | Merged Raw Obs |
|---|---|---|---|---|---|---|
| **F-01** | owasp.org:443 (ASSET-00027) | MEDIUM (5.5) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [owasp.org:443] Missing HTTP Security Headers Baseline (3 endpoints on origin) | CWE-693 (VERSION_DETECTED) | 15 raw / 3 ep |
| **F-02** | google-gruyere.appspot.com:443 (ASSET-00029) | MEDIUM (5.5) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [google-gruyere.appspot.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) | CWE-693 (VERSION_DETECTED) | 5 raw / 1 ep |
| **F-03** | pentesterlab.com:443 (ASSET-00031) | MEDIUM (5.5) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [pentesterlab.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) | CWE-693 (VERSION_DETECTED) | 2 raw / 1 ep |
| **F-04** | www.hackthebox.com:443 (ASSET-00032) | MEDIUM (5.5) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [www.hackthebox.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) | CWE-693 (VERSION_DETECTED) | 3 raw / 1 ep |

| ID | Origin Host:Port (Asset) | Severity (CVSS) | Proof Category & Substate | Consolidated Title | CVE / CWE & Validation | Merged Raw Obs |
|---|---|---|---|---|---|---|
| **F-05** | tryhackme.com:443 (ASSET-00033) | MEDIUM (5.5) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [tryhackme.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) | CWE-693 (VERSION_DETECTED) | 5 raw / 1 ep |
| **F-06** | www.root-me.org:443 (ASSET-00035) | MEDIUM (5.5) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [www.root-me.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) | CWE-693 (VERSION_DETECTED) | 3 raw / 1 ep |
| **F-07** | www.hackinghub.io:443 (ASSET-00036) | MEDIUM (5.5) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [www.hackinghub.io:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) | CWE-693 (VERSION_DETECTED) | 3 raw / 1 ep |
| **F-08** | pentest-ground.com:443 (ASSET-00037) | MEDIUM (5.5) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [pentest-ground.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) | CWE-693 (VERSION_DETECTED) | 5 raw / 1 ep |
| **F-09** | genai.owasp.org:443 (ASSET-00038) | MEDIUM (5.5) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [genai.owasp.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) | CWE-693 (VERSION_DETECTED) | 5 raw / 1 ep |
| **F-10** | vwad.owasp.org:443 (ASSET-00040) | MEDIUM (5.5) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [vwad.owasp.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) | CWE-693 (VERSION_DETECTED) | 5 raw / 1 ep |
| **F-11** | portswigger.net:443 (ASSET-00030) | LOW (3.1) | OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED | [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (Admin Console Unproven) (HTTP 200) on https://portswigger.net/web-security/dashboard | CWE-284 (VERSION_DETECTED) | 1 raw / 1 ep |
| **F-12** | www.root-me.org:443 (ASSET-00035) | LOW (3.1) | OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED | [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (Admin Console Unproven) (HTTP 200) on https://www.root-me.org/admin | CWE-284 (VERSION_DETECTED) | 1 raw / 1 ep |
| **F-13** | github.com:443 (ASSET-00028) | LOW (3.2) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [github.com:443] Missing HTTP Security Headers Baseline (30 endpoints on origin) | CWE-693 (VERSION_DETECTED) | 30 raw / 30 ep |
| **F-14** | portswigger.net:443 (ASSET-00030) | LOW (3.2) | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [portswigger.net:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) | CWE-693 (VERSION_DETECTED) | 2 raw / 1 ep |
| **F-15** | www.hackthissite.org:443 (ASSET-00034) | LOW (3.1) | OBSERVATION_CONFIRMED :: PRE_AUTH_FORM_CSRF_OBSERVED | [www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login | CWE-352 (VERSION_DETECTED) | 2 raw / 1 ep |
| **F-16** | pentest-ground.com:443 (ASSET-00037) | LOW (2.5) | OBSERVATION_CONFIRMED :: VERSION_FINGERPRINT_BANNER_ONLY | [VER-INTEL-001] Software Version Banner Fingerprint Observed (Current Release): nginx 1.31.8 (Legacy Release) | CWE-1104 (VERSION_DETECTED) | 1 raw / 1 ep |
| **F-17** | github.com:443 (ASSET-00028) | LOW (2.4) | OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED | [github.com:443] API Endpoint Missing Rate-Limiting Telemetry Headers (OWASP API4:2023) (7 endpoints on origin) | CWE-770 (VERSION_DETECTED) | 7 raw / 7 ep |

| ID | Origin Host:Port (Asset) | Severity (CVSS) | Proof Category & Substate | Consolidated Title | CVE / CWE & Validation | Merged Raw Obs |
|---|---|---|---|---|---|---|
| F-18 | www.root-me.org:443 (ASSET-00035) | LOW (2.0) | OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED | [API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Observed (/.within.website/x/cmd/anubis/api/honeypot/b9c7a685-3978-43e7-9d99-b96b6af701d2/init) | CWE-284 (VERSION_DETECTED) | 1 raw / 1 ep |

## 3A.1 Detailed Technical Findings & Cryptographic Evidence Cards

### F-01: [owasp.org:443] Missing HTTP Security Headers Baseline (3 endpoints on origin) [owasp.org:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00027 \| owasp.org:443 \| Effective Origin: https://owasp.org:443 (3 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://owasp.org:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 40.7 / 100) |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 15 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA, HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA, HTTP-HEADER-CONTENT_SECURITY_POLICY::T45_OWASP_ORG_WWW_PROJECT_MCP_TO, HTTP-HEADER-X_FRAME_OPTIONS::T45_OWASP_ORG_WWW_PROJECT_MCP_TO, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-REFERRER_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_) |
| **Technical Description** | [Target: https://owasp.org/www-project-juice-shop/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://owasp.org:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1210/retest/execute on owasp.org:443 (ASSET-00027) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-01 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_):**

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_  |  Consolidated
Root-Cause Group: 443:http-headers:security-header-policy-group:origin_owasp_org_443
Immutable Provenance: Asset=ASSET-00027 | Effective Origin=https://owasp.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://owasp.org:443')
Merged Raw Scanner Observations (15 across 3 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA,
HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA,
HTTP-HEADER-CONTENT_SECURITY_POLICY::T45_OWASP_ORG_WWW_PROJECT_MCP_TO,
HTTP-HEADER-X_FRAME_OPTIONS::T45_OWASP_ORG_WWW_PROJECT_MCP_TO,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-REFERRER_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_
EvidenceCore SHA-256 Digest: e5d0159d4709286ca2567ac93429b9a51fb4e177fa02b3c6a2d9901a1b9c14bd (Artifact
#1210 | Unique Forensic Transcript)
```

### F-02: [google-gruyere.appspot.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [google-gruyere.appspot.com:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00029 \| google-gruyere.appspot.com:443 \| Effective Origin: https://google-gruyere.appspot.com:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://google-gruyere.appspot.com:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 40.7 / 100) |

| | |
|---|---|
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-REFERRER_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-PERMISSIONS_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM) |
| **Technical Description** | [Target: https://google-gruyere.appspot.com/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://google-gruyere.appspot.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1244/retest/execute on google-gruyere.appspot.com:443 (ASSET-00029) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-02 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM):**

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM  |  Consolidated
Root-Cause Group: 443:http-headers:security-header-policy-group:origin_google_gruyere_appspot_com_443
Immutable Provenance: Asset=ASSET-00029 | Effective Origin=https://google-gruyere.appspot.com:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin
'https://google-gruyere.appspot.com:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-REFERRER_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM
EvidenceCore SHA-256 Digest: 860f8a3a5a8d625d0a216899829742ec487da801ba45be5a96225ed38051d82d (Artifact
#1244 | Unique Forensic Transcript)
```

## F-03: [pentesterlab.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [pentesterlab.com:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00031 \| pentesterlab.com:443 \| Effective Origin: https://pentesterlab.com:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://pentesterlab.com:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 40.7 / 100) |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 2 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM, HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM) |
| **Technical Description** | [Target: https://pentesterlab.com/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://pentesterlab.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1291/retest/execute on pentesterlab.com:443 (ASSET-00031) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-03 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM):**

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_pentesterlab_com_443
Immutable Provenance: Asset=ASSET-00031 | Effective Origin=https://pentesterlab.com:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://pentesterlab.com:443')
Merged Raw Scanner Observations (2 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM
EvidenceCore SHA-256 Digest: e8e38cd3e701b5f09fa0af0c10b2680cf53956be7f54b48caebf9a85e6c7558f (Artifact
#1291 | Unique Forensic Transcript)
```

## F-04: [www.hackthebox.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [www.hackthebox.com:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00032 \| www.hackthebox.com:443 \| Effective Origin: https://www.hackthebox.com:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.hackthebox.com:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 40.7 / 100) |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 3 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM, HTTP-HEADER-PERMISSIONS_POLICY::T37_WWW_HACKTHEBOX_COM) |
| **Technical Description** | [Target: https://www.hackthebox.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://www.hackthebox.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1296/retest/execute on www.hackthebox.com:443 (ASSET-00032) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-04 / HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM):**

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_www_hackthebox_com_443
Immutable Provenance: Asset=ASSET-00032 | Effective Origin=https://www.hackthebox.com:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://www.hackthebox.com:443')
Merged Raw Scanner Observations (3 across 1 endpoint(s)):
HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T37_WWW_HACKTHEBOX_COM
EvidenceCore SHA-256 Digest: 95e84ea051dcbb2157188e9072b4c3254a0b7eba71ff76f7bd9deb314b52aa4b (Artifact
#1296 | Unique Forensic Transcript)
```

## F-05: [tryhackme.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [tryhackme.com:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00033 \| tryhackme.com:443 \| Effective Origin: https://tryhackme.com:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://tryhackme.com:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 40.7 / 100) |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-REFERRER_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-PERMISSIONS_POLICY::T38_TRYHACKME_COM) |
| **Technical Description** | [Target: https://tryhackme.com/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit. |

| | |
|---|---|
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://tryhackme.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1298/retest/execute on tryhackme.com:443 (ASSET-00033) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-05 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM):**

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_tryhackme_com_443
Immutable Provenance: Asset=ASSET-00033 | Effective Origin=https://tryhackme.com:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://tryhackme.com:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-REFERRER_POLICY::T38_TRYHACKME_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T38_TRYHACKME_COM
EvidenceCore SHA-256 Digest: 3dc6e9f57f5460dd669ec793016844b127b5045255e969b0589218cca9295d5f (Artifact
#1298 | Unique Forensic Transcript)
```

## F-06: [www.root-me.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [www.root-me.org:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00035 \| www.root-me.org:443 \| Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 40.7 / 100) |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 3 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T40_WWW_ROOT_ME_ORG) |
| **Technical Description** | [Target: https://www.root-me.org/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://www.root-me.org:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1307/retest/execute on www.root-me.org:443 (ASSET-00035) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-06 / HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG):**

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00035 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443')
Merged Raw Scanner Observations (3 across 1 endpoint(s)):
HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG,
HTTP-HEADER-PERMISSIONS_POLICY::T40_WWW_ROOT_ME_ORG
EvidenceCore SHA-256 Digest: 2789a1cbde9d05ab3eb2204bc0603e3482aa5c10d1c079058729b087c6d34929 (Artifact
#1307 | Unique Forensic Transcript)
```

## F-07: [www.hackinghub.io:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [www.hackinghub.io:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00036 \| www.hackinghub.io:443 \| Effective Origin: https://www.hackinghub.io:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.hackinghub.io:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 40.7 / 100) |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |

| | |
|---|---|
| **Deduplicated Observations** | 3 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO, HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO, HTTP-HEADER-PERMISSIONS_POLICY::T41_WWW_HACKINGHUB_IO) |
| **Technical Description** | [Target: https://www.hackinghub.io/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://www.hackinghub.io:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1309/retest/execute on www.hackinghub.io:443 (ASSET-00036) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-07 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO):**

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_www_hackinghub_io_443
Immutable Provenance: Asset=ASSET-00036 | Effective Origin=https://www.hackinghub.io:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://www.hackinghub.io:443')
Merged Raw Scanner Observations (3 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO,
HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO,
HTTP-HEADER-PERMISSIONS_POLICY::T41_WWW_HACKINGHUB_IO
EvidenceCore SHA-256 Digest: c8effe1264345388a311385ca21a9e2eba0e1108bfd00c1f54f1e370a3da3155 (Artifact
#1309 | Unique Forensic Transcript)
```

## F-08: [pentest-ground.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [pentest-ground.com:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00037 \| pentest-ground.com:443 \| Effective Origin: https://pentest-ground.com:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://pentest-ground.com:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 40.7 / 100) |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM, HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T42_PENTEST_GROUND_COM, HTTP-HEADER-REFERRER_POLICY::T42_PENTEST_GROUND_COM, HTTP-HEADER-PERMISSIONS_POLICY::T42_PENTEST_GROUND_COM) |
| **Technical Description** | [Target: https://pentest-ground.com/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://pentest-ground.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1313/retest/execute on pentest-ground.com:443 (ASSET-00037) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-08 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM):**

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_pentest_ground_com_443
Immutable Provenance: Asset=ASSET-00037 | Effective Origin=https://pentest-ground.com:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://pentest-ground.com:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM,
HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T42_PENTEST_GROUND_COM,
HTTP-HEADER-REFERRER_POLICY::T42_PENTEST_GROUND_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T42_PENTEST_GROUND_COM
EvidenceCore SHA-256 Digest: c49a04f68702ba7acc446cef0c35d2e47277e5c179c09b6c82db53cd31ce0adc (Artifact
#1313 | Unique Forensic Transcript)
```

## F-09: [genai.owasp.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)

### [genai.owasp.org:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00038 \| genai.owasp.org:443 \| Effective Origin: https://genai.owasp.org:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://genai.owasp.org:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 40.7 / 100) |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T43_GENAI_OWASP_ORG, HTTP-HEADER-REFERRER_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T43_GENAI_OWASP_ORG) |
| **Technical Description** | [Target: https://genai.owasp.org/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://genai.owasp.org:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1319/retest/execute on genai.owasp.org:443 (ASSET-00038) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-09 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG):**

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_genai_owasp_org_443
Immutable Provenance: Asset=ASSET-00038 | Effective Origin=https://genai.owasp.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://genai.owasp.org:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG,
HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T43_GENAI_OWASP_ORG,
HTTP-HEADER-REFERRER_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T43_GENAI_OWASP_ORG
EvidenceCore SHA-256 Digest: f9244cb5ca9f703d357c4285311240eb34a19bb633d132a8fad2281c335c5281 (Artifact
#1319 | Unique Forensic Transcript)
```

## F-10: [vwad.owasp.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)

### [vwad.owasp.org:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00040 \| vwad.owasp.org:443 \| Effective Origin: https://vwad.owasp.org:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://vwad.owasp.org:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 40.7 / 100) |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-REFERRER_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T46_VWAD_OWASP_ORG) |
| **Technical Description** | [Target: https://vwad.owasp.org/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://vwad.owasp.org:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1331/retest/execute on vwad.owasp.org:443 (ASSET-00040) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-10 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG):**

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_vwad_owasp_org_443
Immutable Provenance: Asset=ASSET-00040 | Effective Origin=https://vwad.owasp.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://vwad.owasp.org:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG,
HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T46_VWAD_OWASP_ORG,
HTTP-HEADER-REFERRER_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T46_VWAD_OWASP_ORG
EvidenceCore SHA-256 Digest: 838880739ac13587b624416374a0bf60e51f4a64a8e473e58b2c5730e6ae19ea (Artifact
#1331 | Unique Forensic Transcript)
```

## F-11: [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (Admin Console Unproven) (HTTP 200) on https://portswigger.net/web-security/dashboard [portswigger.net:443 | LOW | CVSS 3.1 | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00030 \| portswigger.net:443 \| Effective Origin: https://portswigger.net:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://portswigger.net:443' |
| **Proof Category & Substate** | OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED (Priority: 26.0 / 100) |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: administrative console exposure, privileged state actions, or authentication bypass (HTTP 200 on /dashboard or /admin path reflects public route or learning page reachability). |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-284 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 1 raw scanner observations merged (DAST-ADMIN-ACCESS-EP-01182) |
| **Technical Description** | Administrative boundary test `ADMIN-ACCESS-001` probed `https://portswigger.net/web-security/dashboard` and received `HTTP 200`. The administrative surface responded with HTTP 200 OK without an authentication gate. |
| **Platform-Aware Remediation** | Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1365/retest/execute on portswigger.net:443 (ASSET-00030) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-11 / DAST-ADMIN-ACCESS-EP-01182):**

```
Finding Key: DAST-ADMIN-ACCESS-EP-01182  |  Consolidated Root-Cause Group:
443:phpmyadmin:phpmyadmin-admin-console-exposure:origin_portswigger_net_443
Immutable Provenance: Asset=ASSET-00030 | Effective Origin=https://portswigger.net:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://portswigger.net:443')
Merged Raw Scanner Observations (1 across 1 endpoint(s)): DAST-ADMIN-ACCESS-EP-01182
EvidenceCore SHA-256 Digest: fea031ce3ea269c91a929038bc3a87d723897145984afcf590a19b159e098b06 (Artifact
#1365 | Unique Forensic Transcript)
```

## F-12: [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (Admin Console Unproven) (HTTP 200) on https://www.root-me.org/admin [www.root-me.org:443 | LOW | CVSS 3.1 | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00035 \| www.root-me.org:443 \| Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443' |
| **Proof Category & Substate** | OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED (Priority: 26.0 / 100) |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: administrative console exposure, privileged state actions, or authentication bypass (HTTP 200 on /dashboard or /admin path reflects public route or learning page reachability). |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-284 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 1 raw scanner observations merged (DAST-ADMIN-ACCESS-EP-01314) |
| **Technical Description** | Administrative boundary test `ADMIN-ACCESS-001` probed `https://www.root-me.org/admin` and received `HTTP 200`. The administrative surface responded with HTTP 200 OK without an authentication gate. |
| **Platform-Aware Remediation** | Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA. |

| | |
|---|---|
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1366/retest/execute on www.root-me.org:443 (ASSET-00035) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-12 / DAST-ADMIN-ACCESS-EP-01314):**

```
Finding Key: DAST-ADMIN-ACCESS-EP-01314  |  Consolidated Root-Cause Group:
443:phpmyadmin:phpmyadmin-admin-console-exposure:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00035 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443')
Merged Raw Scanner Observations (1 across 1 endpoint(s)): DAST-ADMIN-ACCESS-EP-01314
EvidenceCore SHA-256 Digest: 4b15f73195e891218fd2557fe3b4250f66fe1fc8aa050f9faaf2a0fac98c9bf8 (Artifact
#1366 | Unique Forensic Transcript)
```

## F-13: [github.com:443] Missing HTTP Security Headers Baseline (30 endpoints on origin) [github.com:443 | LOW | CVSS 3.2 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00028 \| github.com:443 \| Effective Origin: https://github.com:443 (30 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://github.com:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 24.6 / 100) |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 30 raw scanner observations merged (HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA, HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI, HTTP-HEADER-PERMISSIONS_POLICY::T6_GITHUB_COM_WEBPWNIZED_MUTILL, HTTP-HEADER-PERMISSIONS_POLICY::T7_GITHUB_COM_RAESENE_BWAPP, HTTP-HEADER-PERMISSIONS_POLICY::T8_GITHUB_COM_OWASP_SECURITYSHE, HTTP-HEADER-PERMISSIONS_POLICY::T9_GITHUB_COM_OWASP_NODEGOAT, HTTP-HEADER-PERMISSIONS_POLICY::T10_GITHUB_COM_ADEYOSEMANPUTRA_P, HTTP-HEADER-PERMISSIONS_POLICY::T11_GITHUB_COM_OWASP_RAILSGOAT) |
| **Technical Description** | [Target: https://github.com/digininja/DVWA] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://github.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1216/retest/execute on github.com:443 (ASSET-00028) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-13 / HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA):**

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_github_com_443
Immutable Provenance: Asset=ASSET-00028 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://github.com:443')
Merged Raw Scanner Observations (30 across 30 endpoint(s)):
HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA,
HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI,
HTTP-HEADER-PERMISSIONS_POLICY::T6_GITHUB_COM_WEBPWNIZED_MUTILL,
HTTP-HEADER-PERMISSIONS_POLICY::T7_GITHUB_COM_RAESENE_BWAPP,
HTTP-HEADER-PERMISSIONS_POLICY::T8_GITHUB_COM_OWASP_SECURITYSHE,
HTTP-HEADER-PERMISSIONS_POLICY::T9_GITHUB_COM_OWASP_NODEGOAT,
HTTP-HEADER-PERMISSIONS_POLICY::T10_GITHUB_COM_ADEYOSEMANPUTRA_P,
HTTP-HEADER-PERMISSIONS_POLICY::T11_GITHUB_COM_OWASP_RAILSGOAT
EvidenceCore SHA-256 Digest: 86a71905b68e386e3b85ea468518859c0c419fc8c0177b5fd8f6b58d916b6bbe (Artifact
#1216 | Unique Forensic Transcript)
```

## F-14: [portswigger.net:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [portswigger.net:443 | LOW | CVSS 3.2 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00030 \| portswigger.net:443 \| Effective Origin: https://portswigger.net:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://portswigger.net:443' |
| **Proof Category & Substate** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP (Priority: 24.6 / 100) |

| | |
|---|---|
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 2 raw scanner observations merged (HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY, HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY) |
| **Technical Description** | [Target: https://portswigger.net/web-security] The HTTP response did not include the referrer-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Platform-Aware Remediation** | Enforce baseline HTTP response security headers on origin https://portswigger.net:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1288/retest/execute on portswigger.net:443 (ASSET-00030) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-14 / HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY):**

```
Finding Key: HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_portswigger_net_443
Immutable Provenance: Asset=ASSET-00030 | Effective Origin=https://portswigger.net:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://portswigger.net:443')
Merged Raw Scanner Observations (2 across 1 endpoint(s)):
HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY,
HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY
EvidenceCore SHA-256 Digest: 3670217284fed8316e72f9d6bc3403cf3f2e949c4024f1b7bc3e277fdc4c953f (Artifact
#1288 | Unique Forensic Transcript)
```

## F-15: [www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login [www.hackthissite.org:443 | LOW | CVSS 3.1 | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00034 \| www.hackthissite.org:443 \| Effective Origin: https://www.hackthissite.org:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.hackthissite.org:443' |
| **Proof Category & Substate** | OBSERVATION_CONFIRMED :: PRE_AUTH_FORM_CSRF_OBSERVED (Priority: 24.0 / 100) |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: authenticated state-changing Cross-Site Request Forgery (form is a pre-authentication login/search form). |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-352 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 2 raw scanner observations merged (ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG, ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG) |
| **Technical Description** | [Target: https://www.hackthissite.org/] WebPulse enumerated an HTML `<form method='POST' action='https://www.hackthissite.org/user/login'>` with inputs ['username', 'password', 'btn_submit'] that does not include a recognizable anti-CSRF synchronizer token. |
| **Platform-Aware Remediation** | Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1348/retest/execute on www.hackthissite.org:443 (ASSET-00034) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-15 / ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG):**

```
Finding Key: ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG  |  Consolidated Root-Cause Group:
443:web-app:html-form-missing-csrf-token:origin_www_hackthissite_org_443
Immutable Provenance: Asset=ASSET-00034 | Effective Origin=https://www.hackthissite.org:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://www.hackthissite.org:443')
Merged Raw Scanner Observations (2 across 1 endpoint(s)): ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG,
ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG
EvidenceCore SHA-256 Digest: 5f941e15b4d1a15b4c7c38a0b430f41c7626ba6cdb1843b012182d9a944473fe (Artifact
#1348 | Unique Forensic Transcript)
```

## F-16: [VER-INTEL-001] Software Version Banner Fingerprint Observed (Current Release): nginx 1.31.8 (Legacy Release) [pentest-ground.com:443 | LOW | CVSS 2.5 | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00037 \| pentest-ground.com:443 \| Effective Origin: https://pentest-ground.com:443 (1 Affected Endpoint(s)) |

| | |
|---|---|
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://pentest-ground.com:443' |
| **Proof Category & Substate** | OBSERVATION_CONFIRMED :: VERSION_FINGERPRINT_BANNER_ONLY (Priority: 22.0 / 100) |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: end-of-life (EOL) software status, vulnerable package patch level, or CVE exploitability (response header banner fingerprint only). |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-1104 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 1 raw scanner observations merged (DAST-VER-INTEL-TECH-00131) |
| **Technical Description** | Version intelligence check `VER-INTEL-001` identified fingerprinted component `nginx 1.31.8` (CPE: `cpe:/a:nginx:nginx:1.31.8`, Banner: `[Target URL]: https://pentest-ground.com/ [Effective Origin]: https://pentest-ground.com:443 (ASSET-558B2D) [Scope Decision]: IN_SCOPE (Implicitly authorized primary origin 'https://pentest-ground.com`). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. Outdated software release detected. |
| **Platform-Aware Remediation** | Upgrade nginx (1.31.8) to a current vendor-supported release and apply security advisories. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1389/retest/execute on pentest-ground.com:443 (ASSET-00037) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-16 / DAST-VER-INTEL-TECH-00131):**

```
Finding Key: DAST-VER-INTEL-TECH-00131  |  Consolidated Root-Cause Group:
443:web-app:dast-ver-intel-tech-00131:origin_pentest_ground_com_443
Immutable Provenance: Asset=ASSET-00037 | Effective Origin=https://pentest-ground.com:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://pentest-ground.com:443')
Merged Raw Scanner Observations (1 across 1 endpoint(s)): DAST-VER-INTEL-TECH-00131
EvidenceCore SHA-256 Digest: 5770c507e049f4ebb600320e24b7ea9f431ede4b781de55f1e45a0ee3ba32a3e (Artifact
#1389 | Unique Forensic Transcript)
```

## F-17: [github.com:443] API Endpoint Missing Rate-Limiting Telemetry Headers (OWASP API4:2023) (7 endpoints on origin) [github.com:443 | LOW | CVSS 2.4 | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00028 \| github.com:443 \| Effective Origin: https://github.com:443 (7 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://github.com:443' |
| **Proof Category & Substate** | OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED (Priority: 21.0 / 100) |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: absence of server-side/CDN rate limiting or susceptibility to volumetric brute-force (only response header telemetry absence was observed). |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-770 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 7 raw scanner observations merged (API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI, API-RATE-LIMIT-HEADERS-MISSING::T24_GITHUB_COM_SNOOPYSECURITY_DV, API-RATE-LIMIT-HEADERS-MISSING::T25_GITHUB_COM_EREV0S_VAMPI, API-RATE-LIMIT-HEADERS-MISSING::T26_GITHUB_COM_INE_LABS_REST_API, API-RATE-LIMIT-HEADERS-MISSING::T28_GITHUB_COM_DOLEVF_BLACK_HAT_, API-RATE-LIMIT-HEADERS-MISSING::T29_GITHUB_COM_ROOTXJS_GRPC_GOAT, API-RATE-LIMIT-HEADERS-MISSING::T30_GITHUB_COM_INTERFERENCE_SECU) |
| **Technical Description** | [Target: https://github.com/OWASP/crAPI] API target https://github.com/OWASP/crAPI responded with HTTP 200 (text/html; charset=utf-8) without returning standard rate-limiting headers (RateLimit-Limit / X-RateLimit-Limit). Note: This confirms header absence only; active volumetric throttling was not tested under safe ROE. |
| **Platform-Aware Remediation** | Enforce per-client/token rate limits on API routes and emit RFC-compliant RateLimit-* response headers. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1357/retest/execute on github.com:443 (ASSET-00028) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-17 / API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI):**

```
Finding Key: API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI  |  Consolidated Root-Cause
Group: 443:api-security:missing-rate-limit-headers:origin_github_com_443
Immutable Provenance: Asset=ASSET-00028 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://github.com:443')
Merged Raw Scanner Observations (7 across 7 endpoint(s)):
API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI,
API-RATE-LIMIT-HEADERS-MISSING::T24_GITHUB_COM_SNOOPYSECURITY_DV,
API-RATE-LIMIT-HEADERS-MISSING::T25_GITHUB_COM_EREV0S_VAMPI,
API-RATE-LIMIT-HEADERS-MISSING::T26_GITHUB_COM_INE_LABS_REST_API,
API-RATE-LIMIT-HEADERS-MISSING::T28_GITHUB_COM_DOLEVF_BLACK_HAT_,
API-RATE-LIMIT-HEADERS-MISSING::T29_GITHUB_COM_ROOTXJS_GRPC_GOAT,
API-RATE-LIMIT-HEADERS-MISSING::T30_GITHUB_COM_INTERFERENCE_SECU
EvidenceCore SHA-256 Digest: db3e8234c2219cb326da2ea04624512d169e3a78adae363e8772e274679552c9 (Artifact
#1357 | Unique Forensic Transcript)
```

### F-18: [API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Observed (/.within.website/x/cmd/anubis/api/honeypot/b9c7a685-3978-43e7-9d99-b96b6af701d2/init) [www.root-me.org:443 | LOW | CVSS 2.0 | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00035 \| www.root-me.org:443 \| Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s)) |
| **Scope Provenance Decision** | IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443' |
| **Proof Category & Substate** | OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED (Priority: 18.0 / 100) |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: broken object/function authorization or unauthorized private data disclosure (route is an anti-bot challenge or public API endpoint). |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-284 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 1 raw scanner observations merged (DAST-API-AUTHZ-EP-01309) |
| **Technical Description** | Targeted API authorization check `API-AUTHZ-001` issued an unauthenticated request to `https://www.root-me.org/.within.website/x/cmd/anubis/api/honeypot/b9c7a685-3978-43e7-9d99-b96b6af701d2/init` and received `HTTP 200 OK` (2796 bytes) rather than `401 Unauthorized` or `403 Forbidden`. |
| **Platform-Aware Remediation** | Verify whether this API route is intended to be public; enforce Bearer token / session authentication for non-public APIs. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1364/retest/execute on www.root-me.org:443 (ASSET-00035) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-18 / DAST-API-AUTHZ-EP-01309):**

```
Finding Key: DAST-API-AUTHZ-EP-01309  |  Consolidated Root-Cause Group:
443:web-app:dast-api-authz-ep-01309:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00035 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443')
Merged Raw Scanner Observations (1 across 1 endpoint(s)): DAST-API-AUTHZ-EP-01309
EvidenceCore SHA-256 Digest: 5bf5f69746d0bb333d032ab2ca91caee5e2b87d48f0e58f337083fc163efd186 (Artifact
#1364 | Unique Forensic Transcript)
```

## 3B. Consolidated Reconnaissance Surface & Scanner Health Telemetry

| ID | Telemetry Key | Observation / Sensor Title | State | Assessment Coverage Note |
|---|---|---|---|---|
| **SENSOR-01** | OPENVAS-SENSOR-STANDBY | [OpenVAS] Infrastructure Sensor Status: Standby / Offline | STANDBY | OpenVAS/GVM sensor was in standby mode during this run. Assessment coverage was fulfilled by Nmap v7.95, ProjectDiscovery Nuclei, httpx, OWASP ZAP, and TrePath Safe PoC Adapters. |

## 4. Evidence-Backed Attack Graph, Edge Provenance & Choke-Point Analysis

TrePath 2.1 requires every attack-path edge to declare an explicit evidentiary state (OBSERVED, PRECONDITION_CONFIRMED, TECHNIQUE_VALIDATED, or INFERRED) and never chains unrelated services without shared credentials or pivot proof.

| Path ID | Stage | Finding Key | Edge Evidence State | Step Summary & Rationale | Remediation Chokepoint |
|---|---|---|---|---|---|
| **PATH-00019** | Step 1 (Cleartext HTTP Transport Observation) | TLS-COMPLIANT-CIPHER-TLS_AES_128_GCM_SHA256 | OBSERVED | Compliant TLS Encryption (TLSv1.3 / TLS_AES_128_GCM_SHA256) | Maintain current cryptographic configuration. |
| **PATH-00019** | Step 2 (Diagnostic / Authentication Precondition Exposure) | ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG | INFERRED | [www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login | Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies. |
| **PATH-00019** | Step 3 (Application / Session Policy Boundary Gap) | NMAP-NSE-80-HTTP-HEADERS | INFERRED | [Nmap NSE] http-headers on 80/TCP | Review Nmap NSE 'http-headers' output for port 80 and apply vendor security patches or configuration hardening. |

## 5. Stage 9 (9.1 - 9.7) Exploitation Validation & Post-Exploitation Matrix

Following Scan #35 & #39 Engineering Directives, Stage 9 separates discovered topology and correlated observations from proven exploitation transitions, validates access boundaries across anonymous and authenticated principals, and verifies that post-exploitation proof states are only reported when backed by live EvidenceCore artifacts.

### 5.1 Stage 9.3 & 9.4 Access Boundary & Post-Exploitation Verification Table

| Target Surface | Principal Tested | Verified Boundary State | Proven Capability | Explicitly Unproven Boundary | Artifact & Full SHA-256 |
|---|---|---|---|---|---|
| **phpMyAdmin Web Interface (/phpMyAdmin/)** | Unauthenticated HTTP Client | LOGIN_GATE_ENFORCED (Control Gap: Admin Login Exposed on Network) | HTTP 200 login page reachable over cleartext HTTP | Database administrative login and SQL table access are blocked by authentication gate (not proven) | #1365 (fea031ce3ea269c91a929038bc3a87d723897145984afcf590a19b159e098b06) |

### 5.2 Stage 9.5 Lateral Movement Validation & Stage 9.6 CIA Impact Assessment

| Stage / Dimension | Validation Status | Demonstrated Evidence & Scope Boundary |
|---|---|---|
| **Stage 9.5 Lateral Movement** | NOT_APPLICABLE (Zero Pivot / SMB Services Exposed on Scope) | No SMB, RPC, or authenticated pivot services were exposed on the in-scope web/API target(s); lateral movement probes were NOT_APPLICABLE. |
| **Stage 9.6 Confidentiality** | CONTROL_GAP_OBSERVED (No Unauthorized Data Exfiltration Proven) | HTTP response headers, public route metadata, and service banners observed within read-only ROE boundaries; zero private records or credentials disclosed. |
| **Stage 9.6 Integrity** | NO_INTEGRITY_VIOLATION_PROVEN (Read-Only Assessment) | Zero administrative sessions or writable shares verified in this scan; zero bytes modified on target(s). |
| **Stage 9.6 Availability** | NOT_TESTED (Out of Scope per Non-Destructive ROE) | Zero service disruption; all probes completed within deterministic rate limits. |

## 5B. Exploit Validation Engine (EVE) - Controlled Exploitation Lifecycle & Decisions

TrePath 2.3 Exploit Validation Engine (EVE) bridges vulnerability discovery and remediation by evaluating preconditions, enforcing operator HMAC approval, executing deterministic read-only validation adapters (EVE-AUTH-001, EVE-AUTHZ-001, EVE-INJ-001, EVE-FILE-001, EVE-NET-001), and distinguishing Vulnerability Detected, Exploitability Validated, Impact Verified, and Remediation Verified.

| 4-Tier Platform Distinction | Canonical Tier Code | Validated Job Count | Evidentiary Standard |
|---|---|---|---|
| **1. Vulnerability Detected** | VULNERABILITY_DETECTED | 0 | Scanner or passive control observation confirmed in scope. |

| 4-Tier Platform Distinction | Canonical Tier Code | Validated Job Count | Evidentiary Standard |
|---|---|---|---|
| **2. Exploitability Validated** | EXPLOITABILITY_VALIDATED | 0 | Preconditions satisfied and deterministic test reproduced behavior. |
| **3. Impact Verified** | **IMPACT_VERIFIED** | 0 | Controlled test established unauthorized access, privilege escalation, or data exposure. |
| **4. Remediation Verified** | REMEDIATION_VERIFIED | 0 | Subsequent RTEX retest proved the security boundary now holds. |

## 6. Four-Tier Evidence-Driven Compliance Control Mapping

| Primary Finding | PCI-DSS v4.0 | NIST SP 800-53 Rev 5 | ISO/IEC 27001:2022 | CIS Controls v8 |
|---|---|---|---|---|
| **HTTP Security Header Policy (CSP/HSTS)** | Req 6.4.1 / 6.4.2 | SC-8 / SI-10 | A.8.26 / A.8.28 | Control 16.11 |
| **TOMCAT-MGR-001 (Admin Console Auth)** | Req 2.2.2 / 8.2.1 | IA-5 / AC-6 | A.5.17 / A.8.2 | Control 4.7 / 5.2 |
| **SMB-LIST-001 (Samba Anonymous Enum)** | Req 1.3.1 / 2.2.4 | AC-3 / SC-7 | A.8.20 / A.8.3 | Control 3.3 / 4.1 |
| **PHPINFO-001 & Legacy Service Hygiene** | Req 2.2.6 / 6.3.3 | CM-6 / SI-2 | A.8.8 / A.8.9 | Control 4.1 / 7.1 |

## 7. ENUMCORE 6-Stage CVE Applicability Validation & Threat Intelligence

| CVE / CWE | Validation State | Preconditions Verified | CVSS | EPSS | CISA KEV | Applicability & Precondition Note |
|---|---|---|---|---|---|---|
| **CWE-693** | VERSION_DETECTED | No (Banner Only) | 5.5 | 8.0% | No | No CVE identifier associated; scored by CWE control category. |
| **CWE-284** | VERSION_DETECTED | No (Banner Only) | 5.3 | 8.0% | No | No CVE identifier associated; scored by CWE control category. |

## 8. Prioritized Remediation Roadmap & 7-Step RTEX Verification Ledger (Stage 8)

| Task ID | Origin Host:Port (Asset) | Priority | Status | Work Package Title | Origin-Accurate Fix Guidance | Verification & Closure Rule |
|---|---|---|---|---|---|---|
| **REM-00124** | portswigger.net:443 (ASSET-00030) | P3-Backlog | open | Remediate DAST-ADMIN-ACCESS-EP-01182: [ADMIN-ACCESS-001] Candidate Route or Login Interface Dis | Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS | Verification Test: TrePath Retest Adapter for DAST-ADMIN-ACCESS-EP-01182 on portswigger.net:443 (ASSET-00030) \| Clo |
| **REM-00125** | pentest-ground.com:443 (ASSET-00037) | P3-Backlog | open | Remediate DAST-VER-INTEL-TECH-00131: [VER-INTEL-001] Software Version Banner Fingerprint Observ | Upgrade nginx (1.31.8) to a current vendor-supported release and apply security advisories. [Affected Asset: pentest-ground.com:443 (AS | Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00131 on pentest-ground.com:443 (ASSET-00037) \| C |
| **REM-00126** | owasp.org:443 (ASSET-00027) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_: [owasp.org:443] | Enforce baseline HTTP response security headers on origin https://owasp.org:443: Content-Security-Policy, X-Frame-Options (or frame-anc | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_ |
| **REM-00127** | google-gruyere.appspot.com:443 (ASSET-00029) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM: [google-gruyere. | Enforce baseline HTTP response security headers on origin https://google-gruyere.appspot.com:443: Content-Security-Policy, X-Frame-Opti | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM o |

| Task ID | Origin Host:Port (Asset) | Priority | Status | Work Package Title | Origin-Accurate Fix Guidance | Verification & Closure Rule |
|---|---|---|---|---|---|---|
| **REM-00128** | pentesterlab.com:443 (ASSET-00031) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM: [pentesterlab.com:443] Mis | Enforce baseline HTTP response security headers on origin https://pentesterlab.com:443: Content-Security-Policy, X-Frame-Options (or fr | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM on penteste |
| **REM-00129** | www.hackthebox.com:443 (ASSET-00032) | P2-Planned | open | Remediate HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM: [www.hackthebox.com:443] Missing | Enforce baseline HTTP response security headers on origin https://www.hackthebox.com:443: Content-Security-Policy, X-Frame-Options (or | Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM on www.hackthebox |
| **REM-00130** | tryhackme.com:443 (ASSET-00033) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM: [tryhackme.com:443] Missing H | Enforce baseline HTTP response security headers on origin https://tryhackme.com:443: Content-Security-Policy, X-Frame-Options (or frame | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM on tryhackme.c |
| **REM-00131** | www.root-me.org:443 (ASSET-00035) | P2-Planned | open | Remediate HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG: [www.root-me.org:443] Missing HTTP | Enforce baseline HTTP response security headers on origin https://www.root-me.org:443: Content-Security-Policy, X-Frame-Options (or fra | Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG on www.root-me.org:4 |
| **REM-00132** | www.hackinghub.io:443 (ASSET-00036) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO: [www.hackinghub.io:443] M | Enforce baseline HTTP response security headers on origin https://www.hackinghub.io:443: Content-Security-Policy, X-Frame-Options (or f | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO on www.hac |
| **REM-00133** | pentest-ground.com:443 (ASSET-00037) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM: [pentest-ground.com:443] | Enforce baseline HTTP response security headers on origin https://pentest-ground.com:443: Content-Security-Policy, X-Frame-Options (or | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM on pentes |
| **REM-00134** | genai.owasp.org:443 (ASSET-00038) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG: [genai.owasp.org:443] Missi | Enforce baseline HTTP response security headers on origin https://genai.owasp.org:443: Content-Security-Policy, X-Frame-Options (or fra | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG on genai.owa |
| **REM-00135** | vwad.owasp.org:443 (ASSET-00040) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG: [vwad.owasp.org:443] Missing | Enforce baseline HTTP response security headers on origin https://vwad.owasp.org:443: Content-Security-Policy, X-Frame-Options (or fram | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG on vwad.owasp |
| **REM-00136** | www.root-me.org:443 (ASSET-00035) | P3-Backlog | open | Remediate DAST-API-AUTHZ-EP-01309: [API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Obse | Verify whether this API route is intended to be public; enforce Bearer token / session authentication for non-public APIs. [Affected As | Verification Test: TrePath Retest Adapter for DAST-API-AUTHZ-EP-01309 on www.root-me.org:443 (ASSET-00035) \| Closur |
| **REM-00137** | www.hackthissite.org:443 (ASSET-00034) | P3-Backlog | open | Remediate ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG: [www.hackthissite.org] [WebPulse] HTML | Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies. [Affected Asse | Verification Test: TrePath Retest Adapter for ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG on www.hackthissite.org: |

| Task ID | Origin Host:Port (Asset) | Priority | Status | Work Package Title | Origin-Accurate Fix Guidance | Verification & Closure Rule |
|---|---|---|---|---|---|---|
| **REM-00138** | github.com:443 (ASSET-00028) | P3-Backlog | open | Remediate API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI: [github.com:443] API Endpo | Enforce per-client/token rate limits on API routes and emit RFC-compliant RateLimit-* response headers. [Affected Asset: github.com:443 | Verification Test: TrePath Retest Adapter for API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI on github.c |

### 8.1A Seven-Step Remediation & Retest Verification Loop (RTEX Lifecycle)

| Step | RTEX Lifecycle Stage | Current Status | Verification & EvidenceCore Protocol |
|---|---|---|---|
| **Step 1** | Baseline Finding Sealed (T0) | COMPLETED | 18 consolidated findings sealed with 9-field provenance & 64-hex SHA-256. |
| **Step 2** | Remediation Assigned (REM-xxxxx) | COMPLETED | 15 origin-bound RemediationTask work packages generated. |
| **Step 3** | Deterministic Retest Executed | STANDBY_AWAITING_FIX | 0 live retest execution(s) recorded via POST /api/v1/findings/{id}/retest/execute. |
| **Step 4** | Negative-Control Validation | READY | Verifies response is not a generic WAF block, anti-bot challenge, or out-of-scope redirect. |
| **Step 5** | EvidenceCore Retest Sealing | READY | Before/after HTTP or TCP transcript sealed with fresh FIPS 180-4 SHA-256 digest. |
| **Step 6** | Closure Decision (REMEDIATION_VERIFIED) | PENDING_CLOSURE | Promotes Finding to REMEDIATION_VERIFIED only when deterministic control check passes. |
| **Step 7** | T1 Post-Retest Risk Recalculation | HYPOTHETICAL_FORECAST_ONLY | Recalculates live T1 risk index; until retest executes, 2.1/10 remains labeled HYPOTHETICAL_PROJECTION. |

### 8.2 Deterministic Retest Execution Ledger (RTEX-xxxxx)

| Retest Key | Target Finding | Execution Status | Resulting Proof State | Evidence Artifact | Verification Notes |
|---|---|---|---|---|---|
| **RTEX-STANDBY** | All Open Findings | AWAITING_PATCH | PENDING_RETEST | EvidenceCore Ready | Use POST /api/v1/findings/{id}/retest/execute after applying remediation to record cryptographic closure proof. |

## 9. EvidenceCore Cryptographic Integrity, Consistency Score & Quality Gates (AT + NG-01..06)

| Gate ID | Verification Domain | Dynamic Acceptance & Negative Quality Gate Rule | Status |
|---|---|---|---|
| **AT-01/02** | Scope & Redirect Provenance | 7-stage scope funnel reconciled (46 requested -> 14 origin assets); external links isolated. | **PASSED** |
| **AT-03..06** | Proof-State Reconciliation | **Executive, Section 1.2 & Stage 9 agree: CONFIRMED_ADMIN_AUTH=0, IMPACT_VERIFIED=0.** | **PASSED** |
| **AT-07/08** | Risk & Port Reconciliation | Open TCP ports reconciled (0 ports); 7 risk dimensions sum (41.5/100) matches headline (41.5/100). | **PASSED** |
| **AT-09/10** | Origin Consolidation & Consistency | 181 raw observations -> 18 unique findings; Consistency=100.0%, Sensor Coverage=83.3%. | **PASSED** |
| **NG-01** | No Admin Exposure Claim from Route Rea | Candidate /dashboard or /admin HTTP 200 routes without verified admin console controls classified as OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED (Low). | **PASSED** |
| **NG-02** | No Outdated Software Claim for Current | Modern versions (e.g. nginx 1.31.8) marked is_outdated=False; banner-only fingerprints use OBSERVATION_CONFIRMED :: VERSION_FINGERPRINT_BANNER_ONLY. | **PASSED** |
| **NG-03** | No API Vulnerability Claim from Anti-B | Anubis / /.within.website/ honeypot and public API routes classified as OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED (Low). | **PASSED** |
| **NG-04** | No Rate-Limit Absence Claim from Missi | Absent X-RateLimit-* headers classified as OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED (Low). | **PASSED** |

| Gate ID | Verification Domain | Dynamic Acceptance & Negative Quality Gate Rule | Status |
|---|---|---|---|
| **NG-05** | Zero Cross-Asset Contamination in Reme | All 15 RemediationTask rows bound to exact finding asset_id and effective_origin host:port. | **PASSED** |
| **NG-06** | No Unverified Post-Remediation Risk Cl | Executed retests = 0; post-hardening 2.1/10 explicitly labeled HYPOTHETICAL_PROJECTION. | **PASSED** |

## 10. Autonomous 8-Stage Orchestration Architecture & Benchmark Summary

| Stage | Engine Module | Execution Outcome |
|---|---|---|
| **Stage 1-2** | Scope & Surface Discovery | Verified 14 in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)), 0 open TCP ports, and 377 HTTP endpoints. |
| **Stage 3** | ENUMCORE 6-Stage CVE Engine | Mapped CPEs and separated precondition-verified KEVs from banner-only candidates. |
| **Stage 4-5** | Policy Engine & Safe PoC Probes | Enforced RoE scope lock & read-only HTTP DAST checks (0 destructive or out-of-scope PoCs executed). |
| **Stage 6-7** | Proof Validator & AttackGraph | Assigned granular proof substates and built per-edge evidence-backed attack chains. |
| **Stage 8** | RiskEngine 2.2 & RTEX Ledger | Computed 7-dimension risk (4.2/10) and generated platform-aware remediation tasks. |

## 11. Sign-Off & Deliverables Attestation

| Role | Attestation Statement | Signature / Timestamp |
|---|---|---|
| **Lead Penetration Tester** | All findings, origins, and PoC transcripts verified against EvidenceCore SHA-256 seals. | SIGNED \| 2026-11-02 13:43 UTC |
| **Principal Security Architect** | TrePath 2.2 AT-01..AT-10 & 26-Rule Quality Gate acceptance checks passed. | VERIFIED \| 2026-11-02 13:43 UTC |
| **Client System Owner** | Acknowledges receipt of prioritized remediation roadmap and RTEX retest workflow. | _____ |